Sprint 4 -Native Helper API Security Assessment & Controls

Field	Detail
Student	Eric Matthew Lopez Morales
Course	CPSC 491
Project	SlideKick
Assigned SOC 2 Criterion	CC6.6 (Logical Access Security)
Jira Tasks	S4-SOC2-NH1, S4-SOC2-NH2

NH1: Native Helper API Security Risk Assessment

1. Endpoint Inventory

- Exposes standard HTTP endpoints used to translate remote controller requests into OS-level keyboard events (e.g., `/next`, `/previous`, `/pause`, `/resume`).

2. Host Configuration & Network Binding

- Operates via a local Flask web server.
- **Historical State:** Bound to `0.0.0.0`, inadvertently exposing the API to the local Wi-Fi network.
- **Current Remediation:** Restated and patched in PR #46 to restrict binding strictly to `127.0.0.1` (localhost loopback).

3. Current Authentication Model

- **Token/Credential Enforcement:** None currently enforced.
- **Access Boundary:** Relies entirely on network interface binding (`127.0.0.1`) to reject inbound requests from external devices.

4. Identified Security Threats

- **Threat 1: Unauthorized Local Process Execution**
    - Without local-client authentication, any rogue application or script running under user-space privileges on the machine can send HTTP requests to `127.0.0.1:5000` and hijack active presentations.
- **Threat 2: Server-Side Request Forgery (SSRF) / Cross-Origin Action**
    - Malicious web pages visited in the user's browser can trigger blind background cross-origin requests to `http://localhost:5000/next`, inducing unintended keystrokes.
- **Threat 3: Regression to External Network Exposure**
    - Accidental reversals of the binding back to `0.0.0.0` during local debugging will immediately expose native controls to local network peers without automated guardrails.

NH2: SOC 2-Aligned API Security Control Specification

1. Applicable SOC 2 Criterion

- **CC6.6:** "The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives."

2. Trust Boundary Definition

- **Trusted Zone:** Strictly confined to the local host operating environment (`127.0.0.1`).
- **Untrusted Zone:** External network devices and untrusted web clients within local browser contexts without explicit Cross-Origin Resource Sharing (CORS) enforcement.

3. API Access Requirements

- **HTTP Method Enforcement:** Command endpoints (e.g., `/next`, `/previous`) must strictly require `POST` methods to eliminate accidental execution through standard `GET` navigations.
- **Service Availability Monitoring:** A dedicated `/health` endpoint must accept `GET` requests for safe polling from the frontend controller.
- **Error Handling & Routing Protections:**
    - Undefined or unsupported routes must uniformly yield `404 Not Found`.

    - Unsupported HTTP methods on registered paths must reliably yield `405 Method Not Allowed`.

4. Measurable Security Validation Test Plan

The following automated regression test cases are specified for execution under NH3:

- **Test 1 -Network Binding Verification:** Assert that the active server host configuration resolves strictly to `127.0.0.1`.
- **Test 2 -Method Restriction Enforcement:** Dispatch a `GET` request to `/next` and assert that the helper returns HTTP `405 Method Not Allowed` without emitting keystrokes.
- **Test 3 -Health Endpoint Availability:** Dispatch a `GET` request to `/health` and assert an HTTP `200 OK` response.
- **Test 4 -Unknown Route Rejection:** Dispatch a request to `/unsupported_route` and assert an HTTP `404 Not Found` response.